

Submission benchmark

600 public vulnerable/fixed cases | Python, JavaScript/TypeScript, Go | 27 September 2026

Result: this diagnostic benchmark does not show an advantage over SAST. The full-hybrid lane is a paired post-hoc composition, not an end-to-end SecureCode pipeline run.

Краткий вывод

В отложенной выборке полнота гибридной композиции составляет 27.8%, а полнота базового статического анализатора составляет 32.5%. Разница равна -4.7 процентного пункта; 95% интервал по группам изменений от -13.9 до +4.7 п.п. включает ноль. Сканер завершил только 347 из 600 кейсов. Остальные 253 ошибки сохранены в знаменателях.

The held-out hybrid-minus-Semgrep recall difference is -4.7 percentage points with a lineage-cluster 95% interval from -13.9 to +4.7 pp. The interval includes zero. The deterministic scanner completed 347 of 600 cases; all 253 failures remain visible in completion denominators.

Results across all cases

Lane	Cells	TP/FP/TN/FN	Precision	Recall	F1	Completed	New calls
Deterministic	600	77/80/220/223	49.0%	25.7%	33.7%	84.7%	0
Scanner-seeded derived	600	20/21/279/280	48.8%	6.7%	11.7%	84.7%	0
DeepSeek model-native	1800	151/148/752/749	50.5%	16.8%	25.2%	100.0%	1800
DeepSeek one-shot	1800	204/188/712/696	52.0%	22.7%	31.6%	100.0%	1800
Full hybrid derived	1800	322/323/577/578	49.9%	35.8%	41.7%	84.7%	0
Semgrep 1.177.0	600	103/103/197/197	50.0%	34.3%	40.7%	100.0%	0

Three-repeat lanes show pooled cell counts. Repetitions are grouped by lineage for confidence intervals and are not independent source cases. Scanner failures remain explicit even when a reused model prediction exists.

Held-out results by language

Language	Lane	Valid	TP/FP/TN/FN	Precision	Recall	F1
Python	Model-native	100.0%	25/31/89/95	44.6%	20.8%	28.4%
Python	One-shot	100.0%	38/38/82/82	50.0%	31.7%	38.8%
Python	Hybrid derived	90.0%	60/64/56/60	48.4%	50.0%	49.2%
Python	Semgrep	100.0%	18/18/22/22	50.0%	45.0%	47.4%
JavaScript/TypeScript	Model-native	100.0%	7/8/112/113	46.7%	5.8%	10.4%
JavaScript/TypeScript	One-shot	100.0%	13/14/106/107	48.1%	10.8%	17.7%
JavaScript/TypeScript	Hybrid derived	72.5%	31/32/88/89	49.2%	25.8%	33.9%
JavaScript/TypeScript	Semgrep	100.0%	13/14/26/27	48.1%	32.5%	38.8%
Go	Model-native	100.0%	15/12/108/105	55.6%	12.5%	20.4%
Go	One-shot	100.0%	21/17/103/99	55.3%	17.5%	26.6%
Go	Hybrid derived	90.0%	27/24/96/93	52.9%	22.5%	31.6%
Go	Semgrep	100.0%	8/7/33/32	53.3%	20.0%	29.1%

Paired comparison: hybrid minus Semgrep recall = 0.3%; 95% lineage-cluster interval -8.9% to 10.0%, from 120 held-out lineage groups and 5,000 deterministic resamples.

Corpus and identity

600 public revisions in 300 vulnerable/fixed lineages. Splits: development 240, calibration 120, held-out 240. Manifest SHA-256:

82459c8c5112105535f0424d715777a03dbc00e82160e264ed8059aac1db897c. Content digest:

sha256:24003f707114d46af60391bfd15ee8d8ad11c4e649309a3f24296c66268dd9c6. Candidate source manifest:

e708cf9aa8972d14ef1996b4855407d958011e204bc7883c9f77e355cb899478 (603 files).

Dataset source: [CVEfixes v1.0.8 on Zenodo](#). The source-cache verification recorded 600 matching content hashes and zero mismatches. Raw code is not included. The dataset manifest uses the license value NOASSERTION.

Cost, provenance and limits

Final-scope API ledger: 6,921 settled attempts, \$10.270833 charged; 11 reservations totaling \$0.037515 remain pending. Settled plus pending exposure: \$10.308348. The ledger includes corrected/retried runs and a duplicate interrupted rerun with no output, so it exceeds the cost attached to scored raw cells.

- The model-native and one-shot lanes are direct DeepSeek classifications of public source. They do not run the full scanner, EvidenceGraph, Auditor, Skeptic, validation and verdict pipeline.
- Scanner-seeded and full-hybrid outputs are post-hoc paired compositions. They reuse raw model results and made zero new API requests.
- Semgrep is scored with a broad any-finding-in-file rule, not a CWE-aligned mapping.
- The full-hybrid completion rate is 57.8%. Recall is below Semgrep on both the full corpus and held-out split. The paired confidence interval includes zero.
- No full repair study was run. Zero unsafe-patch observations are not evidence that generated patches are safe.
- The corpus has 79 CWE labels, one file per case, and no private-code generalization evidence. RAM/VRAM and end-to-end scan time were not measured.
- The current Ollama 0.34.4 demo found one Python CWE-89 candidate but proposed no patch; outcome is INDETERMINATE, so patch applicability, syntax and security regression were not evaluated. A separate historical Ollama 0.16.2 run proposed a patch and passed ephemeral parse/rescan only; the runs are not combined.

Evidence files

Aggregate metrics and confidence intervals: `aggregate.json`

All languages, splits and 79 CWE groups: `stratified-metrics.csv`

Input and output SHA-256 records: `aggregate-output-manifest.json`

Provenance for derived lanes: `lane-composition.json`